

MCCoE CYBERSECURITY APPRENTICESHIP PROGRAM

PROJECT 8 OF 8 — PART 2: FRAMEWORKS + EXECUTIVE SUMMARY
EQUIFAX DATA BREACH (2017)

Unpatched CVE · 147 Million SSNs Stolen · 76 Days Silent · \$575M Settlement

 **THIS PROJECT:** Apply the NIST CSF and pentesting methodology. Write and present your professional Executive Summary. This project ends with your Executive Summary submission (100 points).

PROJECT 8 · DAY 6 MONDAY — NIST CSF — DEFENSIVE FAILURE ANALYSIS 1-2 HRS

 **OBJECTIVE:** Students apply all 5 NIST Cybersecurity Framework functions to identify exactly what the organization did wrong and what they should have done.

PROJECT 8 · DAY 7 TUESDAY — 5 PHASES OF PENTESTING — ATTACKER METHODOLOGY 1-2 HRS

 **OBJECTIVE:** Students map the attacker's actions to the 5 pentesting phases. Think like an attacker to become a better defender.

PROJECT 8 · DAY 8 WEDNESDAY — RECOMMENDATIONS WORKSHOP — "FROM HERE ON OUT" 1-2 HRS

 **OBJECTIVE:** Students develop and workshop 5 specific, actionable recommendations. Peer collaboration to pressure-test each recommendation.

PROJECT 8 · DAY 9 THURSDAY — EXECUTIVE SUMMARY PRESENTATIONS + SUBMISSION (100 PTS DUE) 1-2 HRS

 **OBJECTIVE:** Students complete peer review, deliver professional executive summary presentations, submit, and debrief the full incident.

"FROM HERE ON OUT" — RECOMMENDATIONS REFERENCE

🔗 **NOTE:** These are the controls that, if in place, would have prevented or significantly reduced this breach.

- **MANDATE:** Critical patch SLA — CVEs rated CVSS 9.0+ on internet-facing systems patched within 72 hours, no exceptions
- **MANDATE:** SSL/TLS certificate lifecycle management — automated monitoring and renewal for all certificates
- **MANDATE:** Vulnerability scanning — scan ALL internet-facing applications weekly
- **IMPLEMENT:** Database activity monitoring — alert on unusual query volumes, off-hours access, bulk retrieval
- **IMPLEMENT:** Web Application Firewall (WAF) — a properly configured WAF could have blocked CVE-2017-5638
- **IMPLEMENT:** Network segmentation — web servers should NOT have direct access to databases containing SSNs
- **IMPLEMENT:** Data minimization — if you don't need to store it, delete it

REFERENCES & RESOURCES

- nvd.nist.gov/vuln/detail/CVE-2017-5638 — full technical details, CVSS score, references
- U.S. House of Representatives Report: "The Equifax Data Breach" (December 2018) — oversight.house.gov
- FTC: "Equifax to Pay \$575 Million" — ftc.gov (July 22, 2019)
- Apache Security Bulletin S2-045 — struts.apache.org/security/security-bulletins
- CISA Known Exploited Vulnerabilities Catalog: cisa.gov/known-exploited-vulnerabilities-catalog
- MITRE ATT&CK: attack.mitre.org — search T1190, T1059, T1048